

14-828: Homework 2

Due: See Canvas

Name:

Andrew ID:

Scores

Part 1 (35 pts max):

Part 2 (15 pts max):

Part 3 (50 pts max + 20 BONUS points):

Total (100 pts max + 20 BONUS points):

Guidelines

- For this homework, you will need to make two submissions:
 - Submit your **writup** in PDF format to the “HW2: Writup” assignment on Gradescope. Your writup should contain an explanation for each of the problems. **For Q1 and Q2, include all code directly in your writup PDF.**
 - Submit your **code** in a zip file to the “HW2: Code” assignment on Gradescope. Your zip file should contain separate folders for each problem named Q1.1, Q1.2, Q1.3, Q1.4, Q2, Q3.1.
- For the writup, start each problem on a new page. You will need to map the sections of your PDF to problems in Gradescope.
 - For Q1 and Q2, you must use at most one page for your explanation for each subproblem (e.g. Q1.1, Q1.2 should each be at most one page). Any code you include does not count towards this limit.
 - For Q3, no page restriction is in place, but be concise, professional and neat in your writing.
- Please check your grammar. You won’t be penalized for using incorrect grammar, but you will get penalized if we can’t understand what you are writing.
- Please make sure to back up any claims that you make with evidence, citing sources when needed. Statements without proof or argumentation get no credit.
- **This is not a group assignment. Feel free to discuss the assignment in general terms with other people, but the answers must be your own.** Our academic integrity policy strictly follows the current INI Student Handbook http://www.ini.cmu.edu/current_students/handbook/, section IV-C.
- Late submissions incur penalties as described on the syllabus (first you use up grace credits, then you lose points). If you choose to use a late day, please inform the instructors via a post on Campuswire.
- **For Questions 1 and 3, you may use either Manifest V2 or V3 for writing the Chrome extensions.**

1 Baby's First Chrome Extension (35 points)

In this section, we will explore the different types of Chrome extensions and how they can behave, and potentially be exploited. We recommend that you take a look at the development guide at <https://developer.chrome.com/docs/extensions> and reference some of the sample extensions provided in the GitHub repo at <https://github.com/GoogleChrome/chrome-extensions-samples>.

You might also want to install your new creations outside of your daily browser. One way to do this is by installing a separate Chromium build (<https://chromium.woolyss.com/>) and doing your experiments there.

1.1 Hello World Browser Action Extension (10 points)

Write a simple browser action extension that upon clicking on the icon, displays a popup which has an input form to key in your name. Upon typing your name in the input element, it should display "Hello {name}!". Your browser extension should include an HTML file (containing the pop-up), a JavaScript file (to enable the interactive element described above), and a CSS file to style the form. Note that the JS and CSS should not be inlined within the HTML file. Document on the write-up what you did and submit your code under the folder Q1.1 in your zip file.

1.2 Content Scripts (7 points)

Modify the extension to create a content script that replaces all occurrences of the word "Chrome" with "Firefox" on the the pages in the Chrome developer extensions page, i.e. pages under the following directory <https://developer.chrome.com/docs/extensions/>. In addition, change the Chrome icon in the top-left to the Firefox icon. For full credit, you would have to include and use external libraries like jQuery in your content script. Document on the write-up what you did and submit your code under the folder Q1.2 in your zip file.

1.3 Content Scripts Part II (8 points)

Modify the above extension again, such that the browser action pop-up from Q1.1 now takes two strings: a string to match against, and a string that replaces the matched strings. Include a form handler that sends a message to a content script for the pages in <https://developer.chrome.com/docs/extensions/>, which then handles the request and replaces all occurrences of the matches with the string to be replaced by. Document on the write-up what you did and submit your code under the folder Q1.3 in your zip file.

1.4 Background Extension (10 points)

In a separate extension project, implement a browser extension that runs in the background and sends **either** the geolocation or IP address of the user to an external server every minute. You do not have to set up an external server, *but you should make sure the code works*. Document on the write-up what you did and submit your code under the folder Q1.4 in your zip file.

2 Universal XSS (15 points)

We have created our very own extension, that informs users when the titles of other tabs that they have become updated! However, there is a tiny vulnerability in the code. Can you use it to exploit visitors of your site that are running that extension? In particular, the visitor will have the extension and a tab which displays the flag. Read the content from the other tabs to win! Solve the Universal XSS problem on the 14828 CTF Server. **Connect to the CTF server dedicated for this class to solve this problem (similar to what you did for HW1)**

The source code for the Universal XSS extension is available on Canvas for your perusal.

Deliverables

In your code submission (zip): Submit any code that you wrote for this problem under the folder Q2.

In your writeup submission (pdf): You must use the following format in your explanation:

- CTF Username
- Flag
- Explain the vulnerability in the program, and explain conceptually how that vulnerability can be exploited to get the flag.
- How did you exploit the vulnerability? List the steps taken and the reasoning behind each step. The TA grading should be able to replicate the exploit following the steps. Feel free to make references to your code! **Note that "use XYZ online solver" is not sufficient - you must explain how the online solver derived the answer for full credit.**
- Append your source code in the same writeup. Your source code should be readable from the writeup PDF itself. Note that this does not count towards the page count above.

3 Privacy Destroying Extension (50 points + 20 BONUS points)

3.1 The Basics (50 Points)

In this section, we will be using knowledge from above to write a privacy destroying extension. In particular, we will write an extension that tracks the user's browsing behavior, and extract as much personal information as possible from the user (just from this extension alone). **You can use either Manifest V2 or V3 to create your extension, whichever you prefer.**

The user agent for *Chromium* driver will install the extension (much like how you installed the extension while developing) and will enable all permissions that are required. The user agent is then guaranteed to perform the following actions:

1. Browse the web normally through the navigation bar (e.g. Reddit, YouTube, etc.)
2. Make web searches on Google
3. Log in to Facebook
4. Make payments at undisclosed vendor websites
5. Disclose personal information on registration web pages
6. Chat with friends on various web chat platforms

Note that you do not have to implement an extension that captures all of the above for full points. **To get full credit for this section, you extension must minimally meet the criteria below:**

1. Be able to record all browsing activity (URLs visited by the User Agent)
2. Be able to exfiltrate data to an external server (where the server writes to a comma separated value file containing the URLs of the site visited)

Deliverables

In your code submission (zip): Submit your code under the folder Q3.1, which should contain the following.

1. A folder containing the code for your extension.
2. Either a *Dockerfile* OR a *Node.js* application for us to set up as the listening server for the exfiltration.
3. A README.md containing step by step instructions on how to run your setup.
4. A **video** showcasing the capabilities of your extension — in particular, you must show that your extension works for the base case (where the user browses a site and it is recorded in your server) and for the bonus cases, if you choose to do so.

In your writeup submission (pdf): Please submit a write-up detailing the method of tracking you have chosen, why you have chosen such a method, and how your extension interacts with the server to exfiltrate data.

Testing

One week before the deadline, we will release a test environment for you to test the extension on a subset of test cases we will run. Please use this test harness to verify that your extension works as expected!

3.2 Bonus (Up to 20 points)

For additional points, you may wish to expand on the capabilities of the extension from the minimal criteria. Here are some suggestions on the areas in which you may pursue in expanding your Chrome extension:

1. Exfiltrating sensitive form data, e.g. username, passwords
2. Keylogging/Mouse tracking
3. Clickjacking
4. Reading configuration
5. Stealing cookies
6. Exfiltrating OS information
7. Stealing data from other open tabs/windows
8. Accessing and exfiltrating localStorage
9. Taking screenshots of current activity
10. Stealing previous browser history
11. Accessing local files
12. Any other interesting things not listed here

You may also explore other areas of improvement, including reducing the set of permissions required to do the tracking, or alternate ways of performing the same exfiltration of data, and weighing the trade-offs of each method.

Grading

In your code submission (zip): For the code that you wrote for Q3.1, comment in the code where you made the modifications related to the bonus. Include a BONUS.md describing briefly what you did. Also include a screen recording of your extension improvements in action, if they extract more data than in Q3.1. *(If your changes break the functionality in Q3.1, you may include your new code in a separate folder Q3.2.)*

In your writeup submission (pdf): Please submit a write-up detailing the modifications that you made, why you made those modifications, and how they improved over the original extension, and any other interesting technical details that you wish to share with us.

The amount of bonus points awarded will be based on effort, coverage, creativity, and technical difficulty. For example, a bonus project which just integrates the geolocation script from Q1 will be awarded less points compared to a project that explores something new.

However, do note that since this is a bonus, we have strict requirements on what you can use. In particular, you are **NOT ALLOWED** to use code from other existing Chrome browser exploitation projects that exists on the web. **You MUST write all code yourself for the bonus section.** We will be using MOSS at the end of the semester to verify that no plagiarism occurred, so make sure you take this seriously!